

iCloud Deception

Ticket Overview

Ticket Number: SOC-22058

Date/Time Reported: 2023-07-28 / 04:09:00 UTC

Assigned Analyst: Jeremiah Tindana (Contractor at MockingCyber)

Affected Endpoint: N/A

Affected User: phishing@pot (test mailbox)

Incident Summary

On July 28, 2023 at 04:09, an employee reported a suspicious email to the SOC after it arrived in their inbox claiming to be from Apple regarding iCloud storage. The email had been sent from an address "Speicher-Icloud", translated iCloud Storage. The user was suspicious because they confirmed from their iPhone that they had several GBs of iCloud space unused. MockingCyber's analyst, Jeremiah Tindana, must review the reported email and determine whether it represents a phishing attempt.

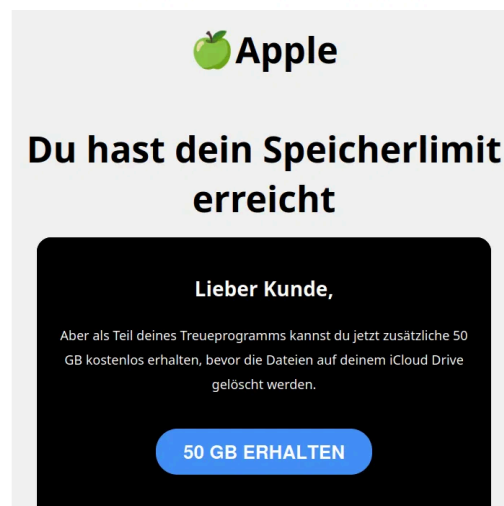
NB: The sample phishing email analyzed in this report (sample-1042.eml) is a real-world phishing sample sourced from a public GitHub phishing-sample repository, phishing pot. All investigation, IOC extraction, and analysis is my own independent work. "MockingCyber" is a fictional consultancy name used for realistic case-report formatting, as is the ticket number. The sending company/recipient identity was not disclosed in the source material and is generalized accordingly.

Investigation

I began by opening the email file (sample-1042.eml) using Thunderbird.

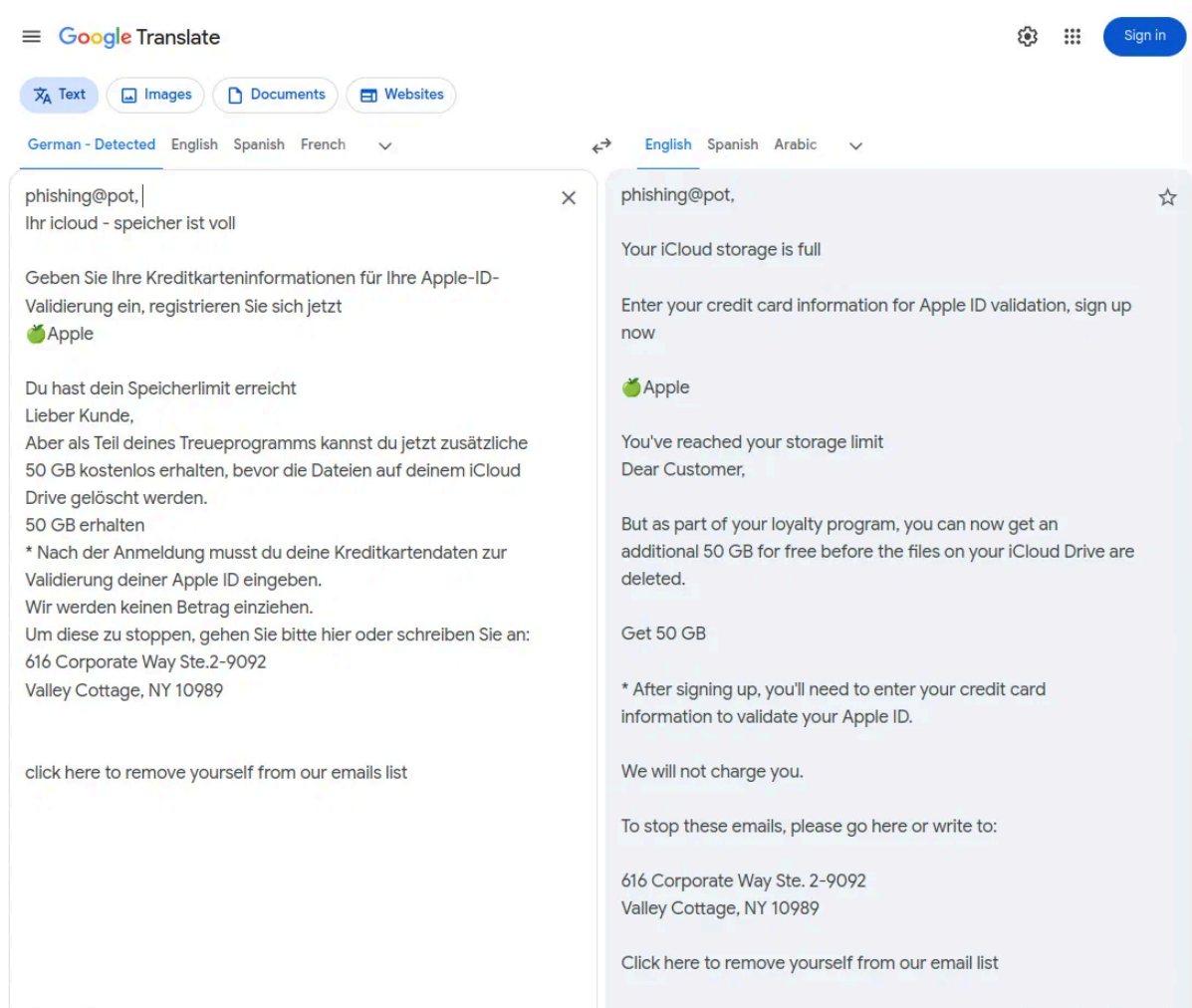
```
mockingcyber@50C201: /Desktop/Investigations/Phishing/phishing_pot$ thunderbird sample-1042.eml
ln: failed to create symbolic link '/home/mockingcyber/snap/thunderbird/1170/.config/dconf/user':
: File exists
Gtk-Message: 13:21:57.152: Not loading module "atk-bridge": The functionality is provided by GTK
natively. Please try to not load it.
```

Picture 1. Thunderbird command to open email file



Picture 2. Email opened in Thunderbird

The email is displayed with a sender display name of "Speicher-Icloud" and a sending address of otto-newsletter@newsletter[.]otto[.]de with a Reply-To of reply_to@winner-win[.]art. I translated the email to English.



Picture 3. Google Translate machine translation of email body

The email tells the recipient their iCloud storage is full, offers 50 GB free as part of a loyalty program before files are deleted, and instructs that after signing up, the recipient must enter credit card information to "validate" their Apple ID, with reassurance that "we will not charge you." That sounds like a tactic commonly used in payment-card phishing to lower the recipient's guard.

The translation also surfaces an unsubscribe and physical-address footer along with a "click here to remove yourself from our emails list" link. This is either an attempt to make the email appear more legitimate, or could indicate this originated from a legitimate newsletter platform that was compromised or abused to send phishing emails. It is also worth noting that the apple logo is an obvious fake.

The display name references iCloud/Apple, but the sending domain (newsletter[.]otto[.]de) resembles Otto, a German retailer with no relation to Apple, and the Reply-To domain (winner-win[.]art) has no obvious relationship with either. The request for credit card details framed as "identity validation" is the clearest social-engineering signal at this point, consistent with a payment-credential harvesting attempt rather than simple credential phishing. Also, the use of incentives to motivate the target is observable.

Using the eioc.py tool, I extracted IPs, URLs, and headers from the email file.

```

mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ python3 ../Tools/eioc.py sample-1042.eml
Extracted IP Addresses:
=====
10[.]233[.]254[.]158
80[.]96[.]157[.]91 - Los Angeles, California, US, ISP: AS9009 M247 Europe SRL

Extracted URLs:
=====
http://www[.]w3[.]org/TR/xhtml1/DTD/xhtml1-transitional[.]dtd
http://www[.]w3[.]org/1999/xhtml
http://bsq2[.]firiri[.]shop/UzRnc1VEaXl2RXpYd05NeUpNss9GZitqSGw5T1BjQXNzcTl3MHdWK0xKWkp0UThjcUhxQWpGUFJWSHhhUz
BoSmFRYTgrdEw2MVNRb2pZWHD0TVZvckE9PQ__
http://bsq2[.]firiri[.]shop/Ymo5TLZWQkVGMitYdzRJV1h1RHRGaFVsMk4zQjREVG4raHF1NLFMTlpjbXcwaGhkTDIyZXNrRG4yYS8raH
dydGV0VWxHMDlmbkRtY3h5NTNkWEpZZnc9PQ__
http://bsq2[.]firiri[.]shop/bjZqV3Z3V2Vta0RvNVZXbXV4SngyYWErWTLtWHBLVWnNcmg0cU40OVRyOFdyMHJHZFVLUVdkSGpPMk0rRL
dwBfcxUmd1OWtESFRFTCtXUkJWcLRBU0E9PQ__
hxxps[://]t[.]co/gDHura2rGc

Extracted Headers:
=====
Authentication-Results: spf=pass (sender IP is 80.96.157.91)
  smtp.mailfrom=winner-win.art; dkim=none (message not signed)
  header.d=none;dmARC=fail action=none header.from=newsletter.otto.de;
From: Speicher-Icloud<otto-newsletter@newsletter.otto.de>
Subject: phishing@pot, Ihr iCloud-Speicher ist voll
Reply-To: reply_to@winner-win.art
To: phishing@pot
Date: Fri, 28 Jul 2023 06:09:33 +0200
Return-Path: return@winner-win.art
X-Sender-IP: 80.96.157.91

Extracted Attachments:
=====
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$

```

Picture 4. IOC output of eioc.py tool

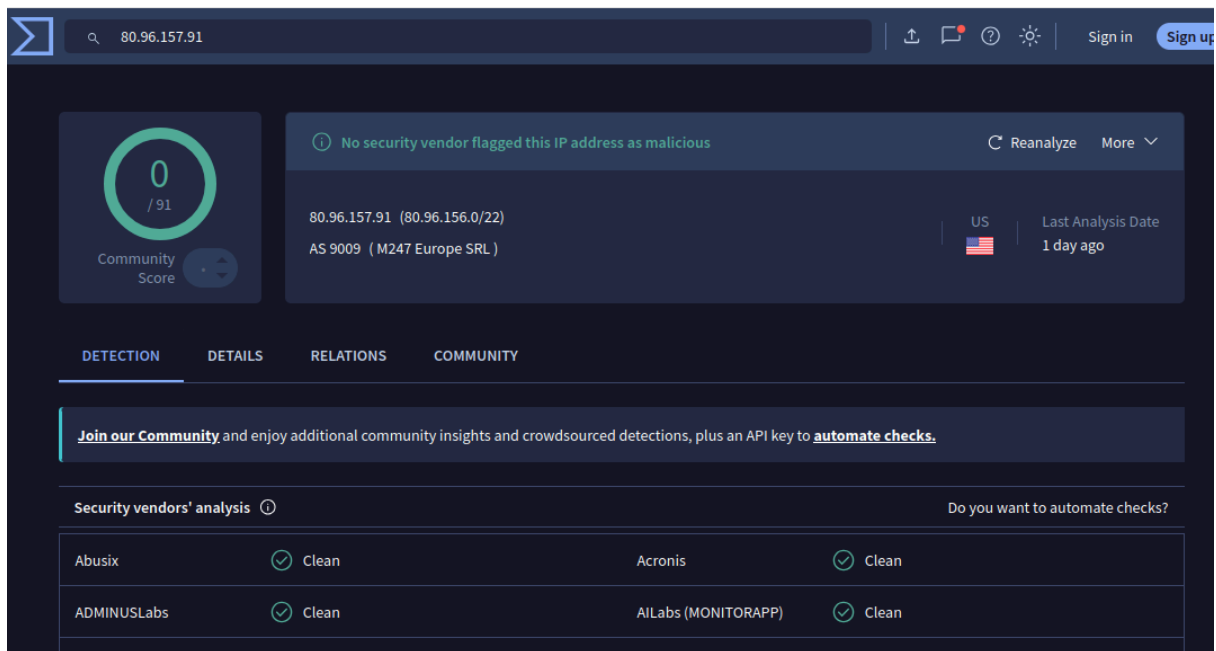
Two IP addresses were extracted: 10[.]233[.]254[.]158 is a private/internal address, likely an internal relay hop. 80[.]96[.]157[.]91 is attributed to M247 Europe SRL infrastructure, geolocated to Los Angeles, California, and matches the X-Sender-IP and the sender IP.

Several URLs were extracted. Two are standard W3C XHTML doctype/namespace references ([http://www\[.\]w3\[.\]org/...](http://www[.]w3[.]org/...)), which are HTML boilerplate. Three point to [bsq2\[.\]firiri\[.\]shop/UzRnc1VEaXl2RXpYd05NeUpNss9GZitqSGw5T1BjQXNzcTl3MHdWK0xKWkp0UThjcUhxQWpGUFJWSHhhUzBoSmFRYTgrdEw2MVNRb2pZWHD0TVZvckE9PQ__](http://bsq2[.]firiri[.]shop/UzRnc1VEaXl2RXpYd05NeUpNss9GZitqSGw5T1BjQXNzcTl3MHdWK0xKWkp0UThjcUhxQWpGUFJWSHhhUzBoSmFRYTgrdEw2MVNRb2pZWHD0TVZvckE9PQ__) each with a different long base64-style path — this pattern (single domain, multiple distinct base64-looking paths) is consistent with per-recipient or per-click tracking/redirect infrastructure, though what it actually redirects to isn't confirmed until visited or scanned. The domain [bsq2\[.\]firiri\[.\]shop](http://bsq2[.]firiri[.]shop) bears no resemblance to Apple or otto.de, reinforcing that this is unrelated third-party infrastructure. There's also a shortened link, [hxxps\[://\]t\[.\]co/gDHura2rGc](http://hxxps[://]t[.]co/gDHura2rGc), a Twitter/X link shortener, whose actual destination is unknown until resolved or unshortened.

DKIM is unsigned, and critically, DMARC fails. The report explicitly notes that the visible From address is [header.from=newsletter\[.\]otto\[.\]de](mailto:header.from=newsletter[.]otto[.]de), while the domain that actually authenticated the send under SPF is [winner-win\[.\]art](mailto:winner-win[.]art). In other words, the address the recipient sees does not match the domain that actually sent the message, and the Return-Path confirms this, listing [return@winner-win\[.\]art](mailto:return@winner-win[.]art) rather than anything tied to otto.de. Here, the pattern points to a spoofed From header sitting on top of unrelated infrastructure at [winner-win\[.\]art](mailto:winner-win[.]art), likely attacker controlled. The DMARC failure is significant because it is exactly the mechanism that should have caused a compliant receiving mail server to quarantine or reject this message rather than deliver it to the inbox.

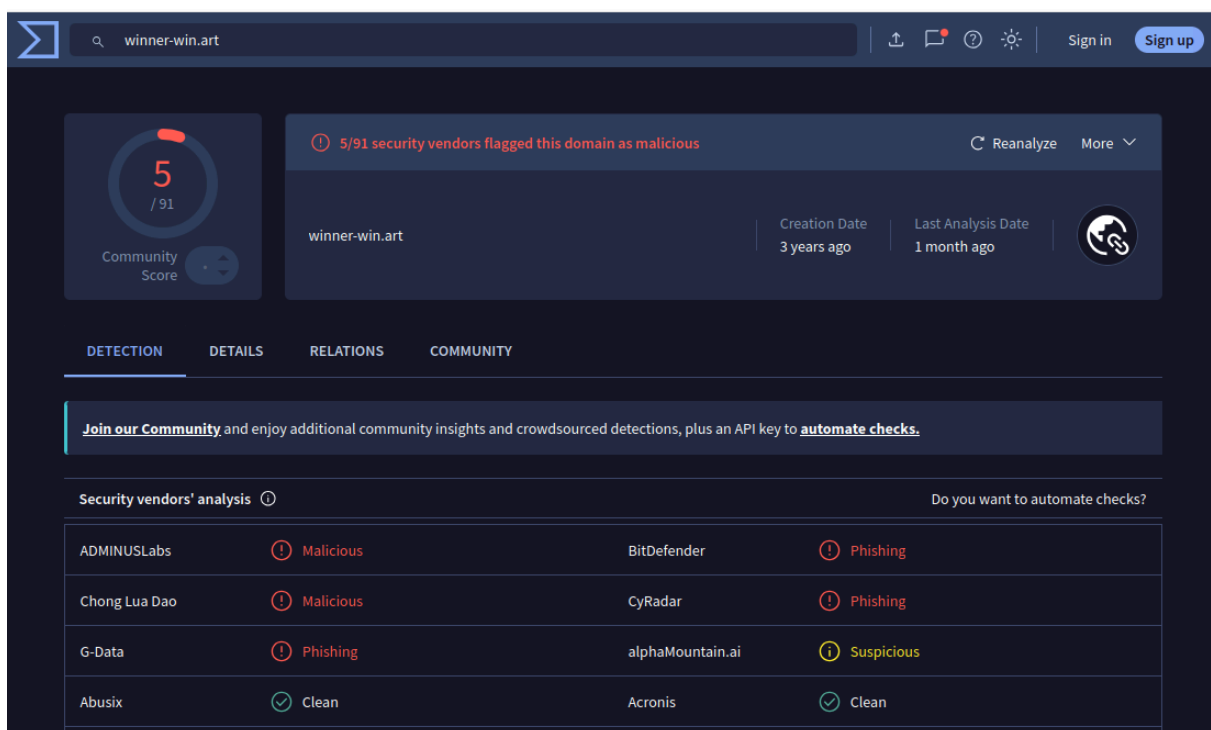
I began dissecting the IOCs extracted to gain some more insight. I began with reputation checks.

I looked up the sender IP (80[.]96[.]157[.]91) on VirusTotal.



Picture 5. IP reputation lookup on VirusTotal

No security vendor flagged this IP address as malicious, with 0 out of 91 detections. I looked up the domain winner-win[.]art on VirusTotal.



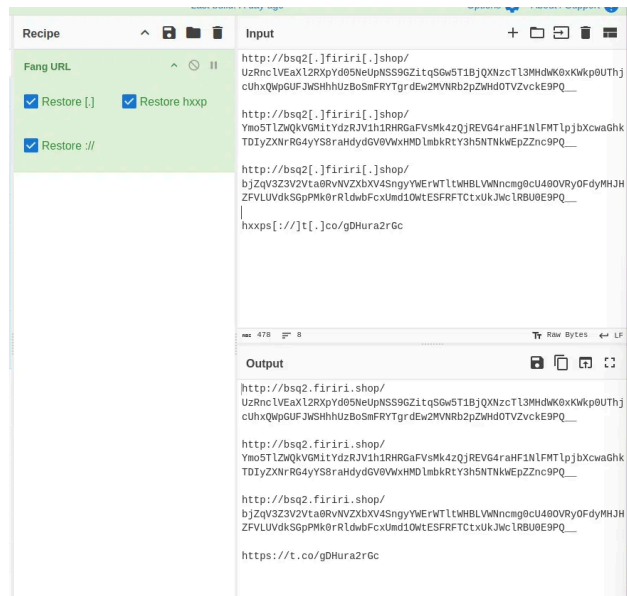
Picture 6. Domain reputation lookup on VirusTotal

5 out of 91 security vendors flagged this domain as malicious. This directly confirms the suspicion raised by the DMARC failure. The domain has an established phishing reputation independent of this specific email.

The domain's creation date is listed as three years ago, meaning it isn't newly registered but an older domain with a sustained pattern of abuse, reinforced by a last analysis date of one month ago showing it's still active and still being flagged. This is consistent with a domain that's been repurposed or persistently used for phishing over time, rather than a one-off.

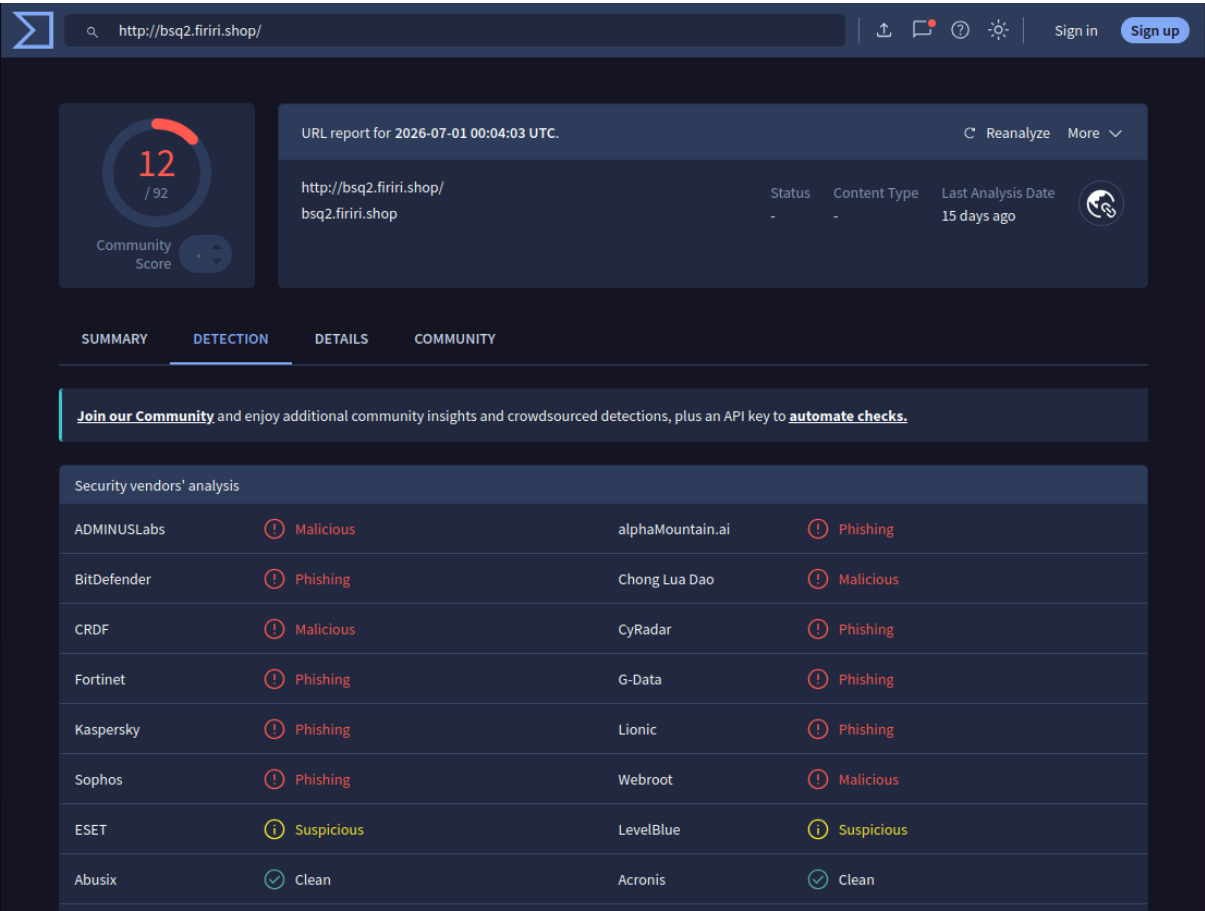
With this information in hand, I proceeded to examine the urls that were extracted. The three [.]firiri URL paths are base64-encoded but resolve to complex data rather than a discoverable email address, campaign ID, or secondary URL, so the actual

purpose is unconfirmed. I used CyberChef's Fang URL recipe against the extracted URLs to restore them to live format for further investigation.



Picture 7. CyberChef to fang URLs

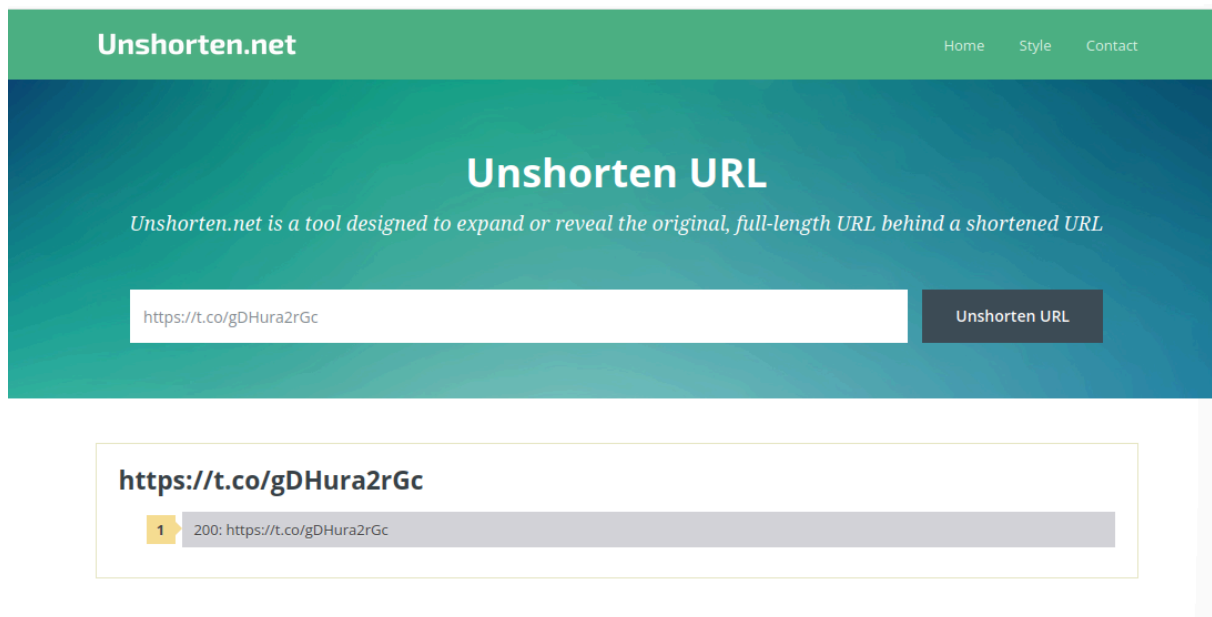
I looked up the base domain, `http://bsq2.firiri.shop/`, on VirusTotal.



Picture 8. URL reputation lookup on VirusTotal

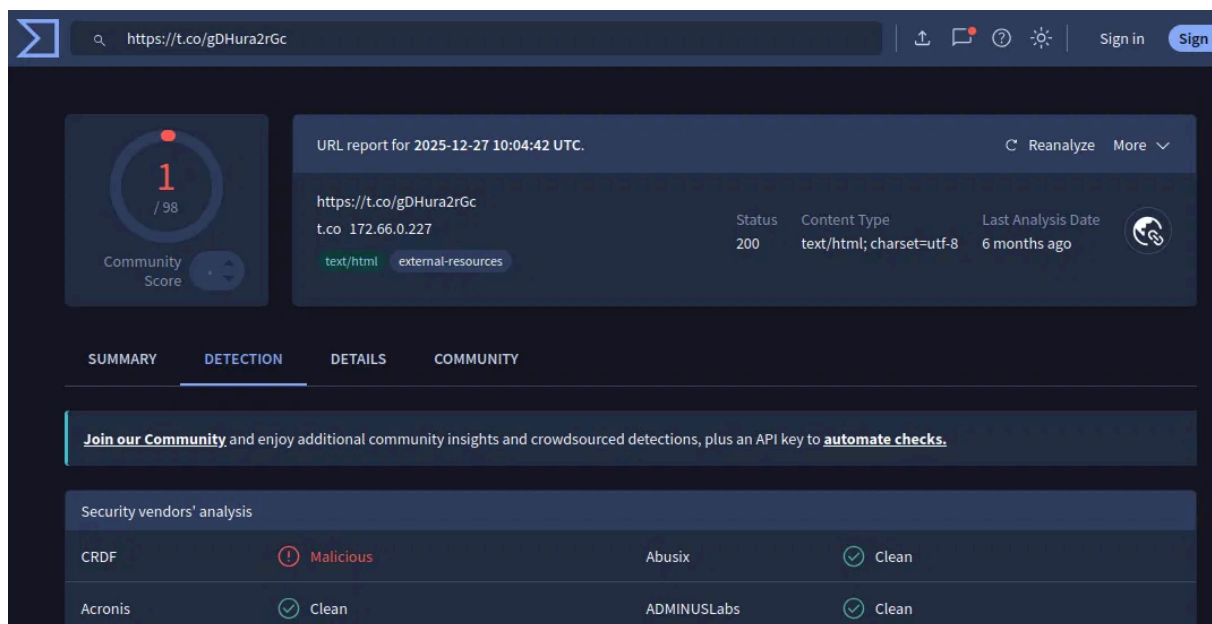
12 out of 92 security vendors flagged this URL as malicious.
Two separate, independently confirmed malicious domains in the same email is a strong indicator of phishing. Attempts to

gain more insight into the nature of these sites using urlscan proved futile and replied with a 404 error code. I ran the shortlink <https://t.co/gDHura2rGc> through Unshorten.net to reveal its destination.



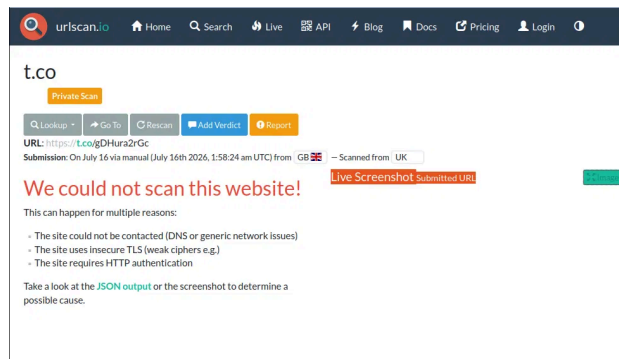
Picture 9. Unshorten[.]net results

The tool returns a single hop which means it resolves back to itself rather than expanding to a further destination. I also looked up the shortlink on VirusTotal.



Picture 10. URL reputation lookup on VirusTotal for shortlink

Only 1 out of 98 vendors flags it as Malicious. The status is listed as 200 with content type text/html, resolving to IP 172[.]66[.]0[.]227. I then submitted the shortlink to urlscan.io.



Picture 11. urlscan.io scan result for shortlink

Urlscan could not contact the site. Unshorten[.]net returned a single hop and VirusTotal also confirms the link is live with an HTTP 200 response. Urlscan.io failed to scan the link, returning a generic "could not scan this website" message common to DNS/network issues, weak TLS, or HTTP-auth-gated sites. This adds no further insight because urlscan does not confirm the exact cause.

Verdict

This email is malicious.

The sending domain is spoofed, not just impersonated. SPF passes only for winner-win[.]art, DKIM is unsigned, and DMARC fails, confirming the visible From address does not match the domain that actually sent the message. The email uses a fake Apple/iCloud storage-full pretext to push the recipient toward entering credit card details under the guise of Apple ID validation. Two separate domains in the delivery chain, winner-win[.]art and bsq2.firir[.]shop, carry independently confirmed phishing/malicious reputations on VirusTotal, and winner-win.art shows a multi-year pattern of sustained abuse rather than one-off use. This is a very likely credential and payment-harvesting phishing email relying entirely on user interaction.

MITRE ATT&CK Mapping

Initial Access — T1566.002 (Phishing: Spearphishing Link): The email delivered a link-based lure impersonating Apple.

Defense Evasion — T1036.005 (Masquerading): The sender spoofed a From address resembling a legitimate Otto newsletter domain while actually sending from unrelated attacker infrastructure.

Initial Access / Execution — T1204.001 (User Execution: Malicious Link): The email required the recipient to click through to a fake Apple ID validation page.

Indicators of Compromise (IOCs)

Domains: winner-win[.]art, bsq2[.]firir[.]shop

Sender IP: 80[.]96[.]157[.]91 (clean reputation but hosting known-malicious domain)

URLs:

hxxp[://]bsq2[.]firir[.]shop/UzRncIvEaXl2RXpYd05NeUpNSS9GZitqSGw5T1BjQXNzcTl3MHdWK0xKWkp0UThjcUhxQWpGUFJW

hxxp[://]bsq2[.]firir[.]shop/Ymo5TlZWQkVGMitYdzRJV1h1RHRGaFVsMk4zQjREVG4raHF1NIFMTlpjbXcwaGhkTDIyZXNrRG4yY!

hxxp[://]bsq2[.]firir[.]shop/bjZqV3Z3V2Vta0RvNVZXbXV4SngyYWErWTltWHBLVWNncmg0cU40OVRyOFdyMHJHJZFVLUVdkSG

hxxps[://]t[.]co/gDHura2rGc

Recommendations

1. Confirm the email remains quarantined or deleted from the reporting employee's mailbox, and does not reach any other inbox.
2. Block the sender domain (winner-win[.]art), the redirect domain (bsq2.firir[.]shop), and the sender IP at the email gateway and web proxy level.
3. Configure or verify the mail gateway's DMARC enforcement policy, since this message failed DMARC and should have been quarantined or rejected automatically rather than reaching an employee's inbox in the first place.

4. Confirm the employee did not click the link or submit any information before reporting it. Advise them, and other staff, not to enter payment card or Apple ID information through emailed links, and to verify iCloud storage status only through Apple's official app or website.
5. Check whether the same sender domain, redirect domain, or subject line pattern has reached other mailboxes, to determine whether this is an isolated report or a wider campaign.
6. If the reporting employee, or anyone else, did click through and submit payment card details before reporting, treat it as a card-compromise incident: notify the cardholder's bank, monitor for fraudulent charges, and consider the associated Apple ID credentials compromised.